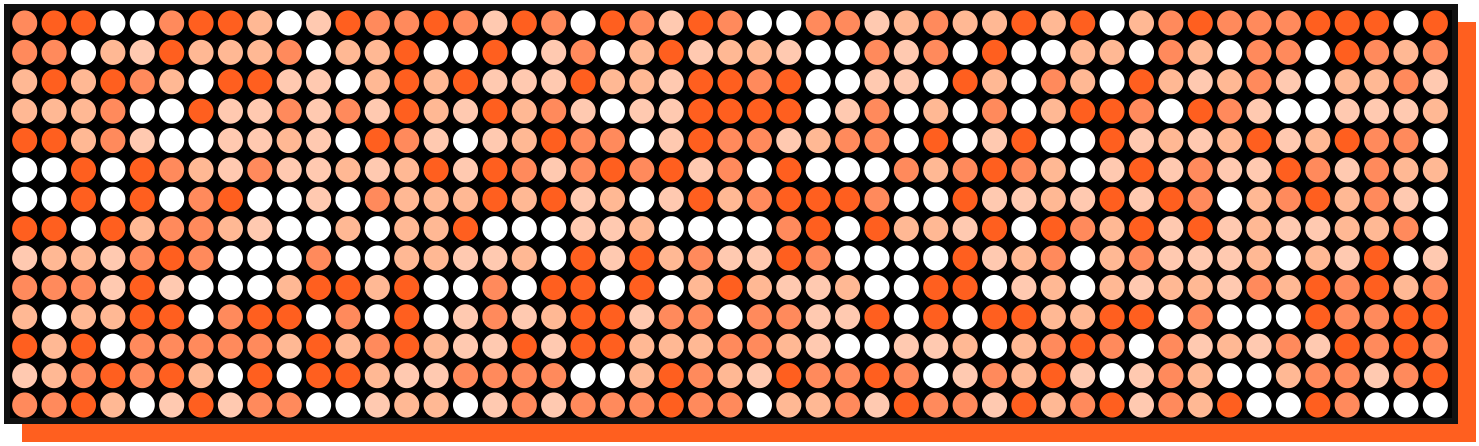
PAPYRUS EVIDENCE PACK

# KNOWN GAPS AND PLAN

Controls awaiting verification, incomplete testing and dependencies on an authorized hosting environment.



| RELEASE | BUILT |
| --- | --- |
| 0.1.0+fd55e38 | 2026-10-20T13:03:06Z |
| **IMAGE** | **INDEX DIGEST** |
| ghcr.io/beaglabs/papyrus/papyrus | sha256:b38facf4950270443ac39dc5bbaeb4ed5653341b6160852 6163e929a449ebd8a |

Prepared by Beag Labs from the Papyrus source and its published release image. Describes the software and the responsibilities it leaves to a deploying organization. It is not a certification, an authorization or a third-party assessment.

# KNOWN GAPS AND REMEDIATION PLAN

Open items for the Papyrus software, including controls that are partly implemented or not yet verified, testing still to be done, and dependencies on an authorized hosting environment. Controls were reviewed against Papyrus source revision `4b3c439aba7e` including changes not yet released. The release image was built from `fd55e3821fda`.

| 33 | 8 | 21 | 4 |
|---|---|---|---|
| OPEN ITEMS | HIGH | MODERATE | LOW |

The same items are in `oscal/papyrus-poam.json` (OSCAL POA&M) and `papyrus-poam.xlsx`, whose columns follow FedRAMP POA&M template headings so they can be merged into a deploying organization's own plan.

| ID | ITEM | GAP | REMEDIATION | MILESTONE |
|---|---|---|---|---|
| **PAP-001** MODERATE | **AC-3 Access Enforcement** AC-3 | Agent sessions, their messages, the AgentFS Library and generated artifacts are owned by the tenant, not by the person who created them. Any signed-in person holding any Papyrus role can list and read every session, Library file and artifact in the deployment. | Record an owner on each session and Library namespace, enforce owner or explicit-share checks in the session, workspace-file and artifact routes, and add tests for cross-user denial. | Before first federal pilot |
| **PAP-002** MODERATE | **AC-4 Information Flow Enforcement** AC-4 | Outbound HTTP from workflow http-get/http-post steps and imported API tools is allowed to any public HTTPS host by default; the organization can block hosts with a denylist but there is no allow-list-only mode. | Add an allow-list mode (deny by default) for workflow and imported-API egress, selectable per deployment profile and on by default for the government and disconnected profiles. | Before first federal pilot |
| **PAP-003** MODERATE | **AC-5 Separation of Duties** AC-5 | Action proposals and governed changes do not check that the approver differs from the person who proposed or requested them, so one person holding the approving roles can approve their own request. Unaddressed workflow approval steps can be answered by the run's initiator. | Refuse approval when the approver's object ID equals the proposer or requester for action proposals, governed changes and unaddressed workflow steps, with an explicit single-operator override recorded in the audit log. | Before first federal pilot |
| **PAP-004** MODERATE | **AC-6 Least Privilege** AC-6 | Possession of any role, including narrow ones such as Papyrus.Audit.View, grants access to the shared agent workspace: all sessions, chat, Library files and artifacts. Workspace access is not itself a separately assignable privilege. | Introduce a distinct workspace-use role or per-session ownership (see ac-3) so that narrow roles do not carry workspace access. | Before first federal pilot |
| **PAP-005** MODERATE | **AC-12 Session Termination** AC-12 | Sessions are stateless: there is no server-side session store, idle timeout, or revocation list. A copied cookie remains valid until its one-hour expiry after sign-out, and on deployments using their own app registration the roles carried in the cookie persist until expiry after an Entra role is removed. | Add a server-side session table with idle timeout, explicit revocation on sign-out, and an administrator action to end a person's sessions. | Before first federal ATO package |
| **PAP-006** MODERATE | **AU-2 Event Logging** AU-2 | Successful and failed sign-ins and authorization denials (401/403) are not written to a local audit record. A successful sign-in is only sent as an analytics event to Beag Labs on registered deployments. | Write sign-in success, sign-in failure and authorization-denied events to an append-only local audit table with actor, time, route and outcome. | Before first federal ATO package |
| **PAP-007** LOW | **AU-3 Content of Audit Records** AU-3 | Audit records do not capture the client network address, and each log uses its own schema, so records cannot be correlated or exported in one format. | Add source address and request ID to audit writes and define a common audit event schema used by all append-only logs. | Before first federal ATO package |
| **PAP-008** MODERATE | **AU-6 Audit Record Review, Analysis, and Reporting** AU-6 | There is no consolidated audit view and no export or forwarding of audit records to an external log store or SIEM; records stay in local SQLite databases. | Provide an audit export API and a streaming forwarder (syslog or OTLP) covering all append-only logs. | Before first federal ATO package |

| ID | ITEM | GAP | REMEDIATION | MILESTONE |
|---|---|---|---|---|
| **PAP-009** MODERATE | **AU-9 Protection of Audit Information** AU-9 | Triggers and the hash chain detect changes made through the application only; anyone with write access to the database file can rewrite them. Chain verification is not exposed through any API or run on a schedule, and logs other than integration and action events are not hash-chained. | Expose chain verification to Audit Viewers, run it periodically, extend chaining to all audit tables, and anchor chain heads in external storage. | Before first federal ATO package |
| **PAP-010** MODERATE | **CM-2 Baseline Configuration** CM-2 | The baseline is not fully reproducible: base images are referenced by tag rather than digest, apk packages are not version-pinned, and several Python packages in the runtime image (pypdf, pypdfium2, reportlab, pillow) are unpinned. | Pin base images by digest and pin apk and pip package versions, with an automated update process that opens reviewed changes. | Next release |
| **PAP-011** LOW | **CM-8 System Component Inventory** CM-8 | The SPDX SBOM records name and version only (licenses and download locations are NOASSERTION) and omits OS and Python packages; the image SBOM is not attached to the published image as a signed attestation. | Publish the image SBOM as a signed attestation alongside the provenance attestation and include license data. | Next release |
| **PAP-012** MODERATE | **CM-14 Signed Components** CM-14 | Signature verification exists only on the Marketplace VM update and image-build paths; the shell updater has no automated test, and other deployment paths do not verify signatures in this repository. The Azure template (deploy/azure/main.bicep) references ghcr.io/beaglabs/papyrus:0.1.1 by tag, a different repository from the one CI publishes (ghcr.io/beaglabs/papyrus/papyrus). Two workflows (container.yml and container-multiarch.yml) sign images for the same repository while the updater trusts only the container.yml identity. | Settle on one signing workflow and identity, reference images by digest from the published repository in every deployment template, add an automated test for the updater verification step, and document signature verification for every supported deployment path. | Next release |
| **PAP-013** HIGH | **RA-5 Vulnerability Monitoring and Scanning** RA-5 | No dependency, static-analysis or image vulnerability scanning runs in CI, and there is no Dependabot or equivalent configuration. | Add image and dependency scanning (for example Grype or Trivy against the CycloneDX SBOM) and static analysis to CI, failing builds on critical findings, and enable automated dependency update pull requests. | Next release |
| **PAP-014** MODERATE | **SA-9 External System Services** SA-9 | On registered deployments the server sends each person's Entra object ID, display name and tenant ID to Beag Labs as analytics on sign-in, and there is no setting to turn analytics off separately from registration. Deployments on the government profile register with Beag Labs unless PAPYRUS_BEAGLABS_REGISTRATION=0 is set. Several outbound destinations (embedding download, package registries) are not listed in docs/deployment.md. The control plane and license authority are not in this repository and are not covered by this assessment. | Add a separate analytics opt-out and stop sending display names, default registration off for the government profile, document every outbound destination with its switch, and publish a security description of the control plane and license authority. | Before first federal pilot |
| **PAP-015** MODERATE | **SA-11 Developer Testing and Evaluation** SA-11 | Most security tests, including identity, MCP, Resource Class intake, Key Vault, broker and control-plane tests, do not run in CI, and the compliance drift check runs only in the local pre-commit hook, which can be skipped. compliance/ssp.md states that these checks run in CI. | Run the full server test suite and pnpm compliance:check in CI on every pull request and make them required checks. | Next release |
| **PAP-016** MODERATE | **SC-5 Denial-of-Service Protection** SC-5 | Rate limits are in memory and keyed on the socket address; behind the appliance's nginx proxy every client shares one address, and the limiter clears all windows once it tracks 10,000 keys. The cap of 256 pending sign-ins can be exhausted by unauthenticated requests, blocking sign-in for up to 10 minutes. | Key limits on a trusted forwarded client address, bound memory without clearing all windows, and rate-limit /api/auth/entra/login per client instead of a global cap. | Before first federal pilot |

| ID | ITEM | GAP | REMEDIATION | MILESTONE |
|---|---|---|---|---|
| **PAP-017** MODERATE | **SC-7 Boundary Protection** SC-7 | The address check resolves DNS separately from the connection that follows, so a host that changes its DNS answer between the two can reach an internal address. The deployment Key Vault is created with public network access enabled. | Connect to the address that was checked (pinned lookup) for all outbound requests, and support private endpoints or firewall rules for the deployment Key Vault. | Before first federal pilot |
| **PAP-018** MODERATE | **SC-12 Cryptographic Key Establishment and Management** SC-12 | There is no rotation or key-versioning support for the portal secret or the local master key. Encryption keys for connector credentials are derived with a single SHA-256 of the portal secret, so changing that secret makes stored values unreadable. The Key Vault uses the Standard (software-protected) tier. | Introduce versioned data-encryption keys with a proper KDF, a re-encryption procedure for rotation, and an option for HSM-backed keys. | Before first federal ATO package |
| **PAP-019** HIGH | **SC-13 Cryptographic Protection** SC-13 | Papyrus does not enable OpenSSL FIPS mode or a FIPS provider, and the image is not built on a FIPS 140 validated cryptographic module. Algorithms in use are FIPS-approved, but no validated module is claimed. | Build a FIPS variant of the image on a FIPS 140-3 validated OpenSSL provider, enable FIPS mode at startup, fail startup if it is unavailable, and test that every code path works under it. | Before first federal ATO package |
| **PAP-020** MODERATE | **SC-28 Protection of Information at Rest** SC-28 | Agent sessions, Library documents, Resource Class records, audit logs and traces are stored in unencrypted SQLite and AgentFS files; their protection at rest depends entirely on volume encryption that Papyrus neither provides nor checks. | Document volume encryption as a deployment requirement and verify it on supported deployment configurations, or add database-level encryption for the main data stores. | Before first federal ATO package |
| **PAP-021** HIGH | **SC-39 Process Isolation** SC-39 | The Factory sidecar, enabled by default in the image (PAPYRUS_FACTORY_SIDECAR=1), runs commands for App builds in Mastra's LocalSandbox with no kernel isolation: only its environment is restricted to an allow-list. Those commands run as the same user as the daemon, can read files that user can read, including the Papyrus data directory, and have network access. | Run Factory sidecar commands under the same landstrip policy as agent workspace commands (data directory denied, network denied or limited to package mirrors and source control), or disable the sidecar by default until that is in place. | Before first federal pilot |
| **PAP-022** MODERATE | **SI-2 Flaw Remediation** SI-2 | Beag Labs has no documented flaw remediation timeframes by severity, and no published security advisory or vulnerability disclosure process (no SECURITY.md). | Publish a vulnerability disclosure policy and severity-based remediation SLAs, and announce fixed vulnerabilities in release notes. | Before first federal pilot |
| **PAP-023** LOW | **SI-11 Error Handling** SI-11 | Unexpected exceptions are returned to the client as 500 INTERNAL_ERROR with the exception's message text, which can disclose internal details. | Return a generic message for unmapped errors and log the detail server-side under the request ID. | Next release |
| **PAP-024** MODERATE | **SR-4 Provenance** SR-4 | GitHub Actions are referenced by mutable version tags rather than commit SHAs, and base images and OS and Python packages in the Dockerfile are not pinned, so build inputs are not fully traceable. | Pin all Actions to commit SHAs and pin image and package inputs (see cm-2), recording them in the provenance attestation. | Next release |
| **PAP-025** HIGH | **No third-party assessment or penetration test** Program | No 3PAO assessment, independent security assessment or penetration test of Papyrus has been performed. All statements in this file are derived from the source repository and its automated tests. | Commission an independent penetration test of the application and appliance, then a 3PAO assessment against the target baseline, and track findings in the POA&M. | Before first federal ATO package |
| **PAP-026** HIGH | **Controls not verified in an authorized hosting environment** Program | Papyrus has not been deployed or assessed within a FedRAMP-authorized or DoD Impact Level authorized boundary, and holds no ATO. The DoD image variant only changes the default Microsoft cloud and embeds the offline license key. | Deploy a reference instance in an authorized environment and verify each control there with a sponsoring agency. | Before first federal ATO package |
| **PAP-027** HIGH | **FIPS 140 validated cryptography not enabled** Program | No code, configuration or image in the repository enables OpenSSL FIPS mode or a FIPS provider. Papyrus uses FIPS-approved algorithms through Node.js crypto but does not run on a validated module. | Produce a FIPS image variant on a FIPS 140-3 validated provider with FIPS mode enforced at startup (see sc-13). | Before first federal ATO package |

| ID | ITEM | GAP | REMEDIATION | MILESTONE |
|---|---|---|---|---|
| **PAP-028** HIGH | **Vulnerability scanning and remediation SLAs not formalized** Program | CI performs no dependency, static or image vulnerability scanning; there are no severity-based remediation timeframes and no published vulnerability disclosure policy. | Add scanning to CI (see ra-5), publish a disclosure policy, and adopt remediation SLAs such as those in the FedRAMP continuous monitoring guidance. | Before first federal pilot |
| **PAP-029** MODERATE | **Incident response and contingency planning owned by the deploying organization** Program | Papyrus ships no incident response plan, contingency plan, or backup tooling. Each deploying organization must cover Papyrus in its own IR and CP documentation, and Beag Labs has no published process for notifying customers of product security incidents. | Publish customer-facing guidance for IR and backup/restore of a Papyrus deployment and a Beag Labs product security incident notification process. | Before first federal pilot |
| **PAP-030** MODERATE | **Security tests and compliance checks not enforced in CI** Program | CI runs type checking and a subset of tests; most security tests and the compliance drift check run only locally through a pre-commit hook that can be bypassed. The generated compliance/ssp.md states that these checks also run in CI. | Run the full test suite and pnpm compliance:check as required CI checks, and correct the SSP text until they do (see sa-11). | Next release |
| **PAP-031** HIGH | **First-run setup is not authenticated** Program | Before identity is configured, the setup server accepts the Entra tenant and client configuration from any caller that can reach it, with no setup token, once Terms are accepted and an entitlement is present. HTTPS is required for this step only on verified Marketplace deployments in persistent mode; elsewhere setup can run over plain HTTP. | Require a one-time setup token printed to the host console or delivered through the deployment channel, and require HTTPS for setup in persistent mode on every deployment path. | Before first federal pilot |
| **PAP-032** MODERATE | **Beag Labs control plane and license authority outside assessment scope** Program | Control-plane deployments trust papyrus.beaglabs.com and license.beaglabs.com to entitle and suspend them, bind their tenant and first System Owner, broker Microsoft sign-in, and issue Graph tokens. That code is not in this repository and none of its controls are documented here. | Produce a separate control description for the control plane and license authority, including signing-key custody, or document the self-registration and disconnected deployment modes as the path for organizations that cannot accept the dependency. | Before first federal pilot |
| **PAP-033** LOW | **Security documentation does not match the implementation in places** Program | compliance/ssp.md and docs/workspace-security-model.md describe the workspace sandbox as nono, while the code applies landstrip (Landlock and seccomp) through files still named workspace-nono; docs/security.md describes the current behavior. | Update the SSP generator text and workspace documentation to name landstrip, and rename the files. | Next release |